02 06 Tag 1 Security Scan (OpenVAS Greenbone)

Scan-Metadaten

Parameter	Wert
Scan gestartet	So, 28. Feb 2021 – 00:04:36 UTC
Scan beendet	So, 28. Feb 2021 – 00:21:02 UTC
Dauer	ca. 16 Minuten
Task Name	Blue
Gescannter Host	10.10.148.71
Scan-Typ	Non-Credentialed
Scan Config	Full and fast
Scanner	OpenVAS Default
Gefilterte Ergebnisse	5 (von 23 Gesamtresultaten)
Mindest-QoD	70

---

1. Theoretischer Hintergrund

Threat Feeds

= Datenbank mit bekannten Schwachstellen (CVEs & NVTs)

Müssen stets aktuell sein, weil:

- Neue Sicherheitslücken täglich entdeckt werden
- Veraltete Feeds zu unvollständigen Scan-Ergebnissen führen
- Nur aktuelle Signaturen neue Angriffsvektoren erkennen

Target

Definiert welche Systeme gescannt werden → IP oder Netzwerk

Targets werden unter *Configuration* → *Targets* erstellt

Credentialed vs. Non-Credentialed

Typ	Erklärung	Vorteil
Non-Credentialed	Scan von außen ohne Login	Simuliert externen Angreifer

Typ	Erklärung	Vorteil
Credentialed	Login ins System	Patchlevel, lokale Configs, Software-Versionen sichtbar

Credentialed Scan liefert mehr Infos, weil er direkten Zugriff auf lokale Systemdaten hat.

CVSS-Bewertungssystem

Stufe	CVSS-Wert	Bedeutung
Critical	9.0 – 10.0	Unmittelbare, vollständige Kompromittierung möglich
High	7.0 – 8.9	Schwere Auswirkungen, sofortiger Handlungsbedarf
Medium	4.0 – 6.9	Ernstzunehmende Risiken, zeitnahe Behebung
Low	0.1 – 3.9	Geringe Auswirkungen, beobachten und planen

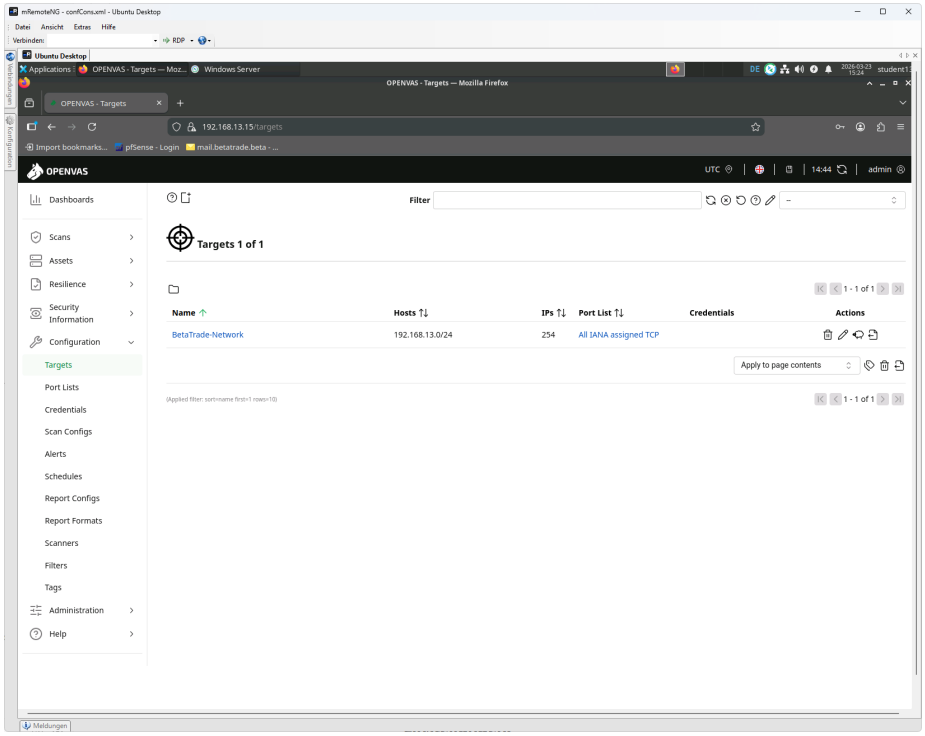
---

2. Scan-Konfiguration

Schritt 1: Target erstellen

Menü: *Configuration → Targets → New Target*

Einstellung	Wert
Name	BetaTrade-Network
Hosts	192.168.13.0/24



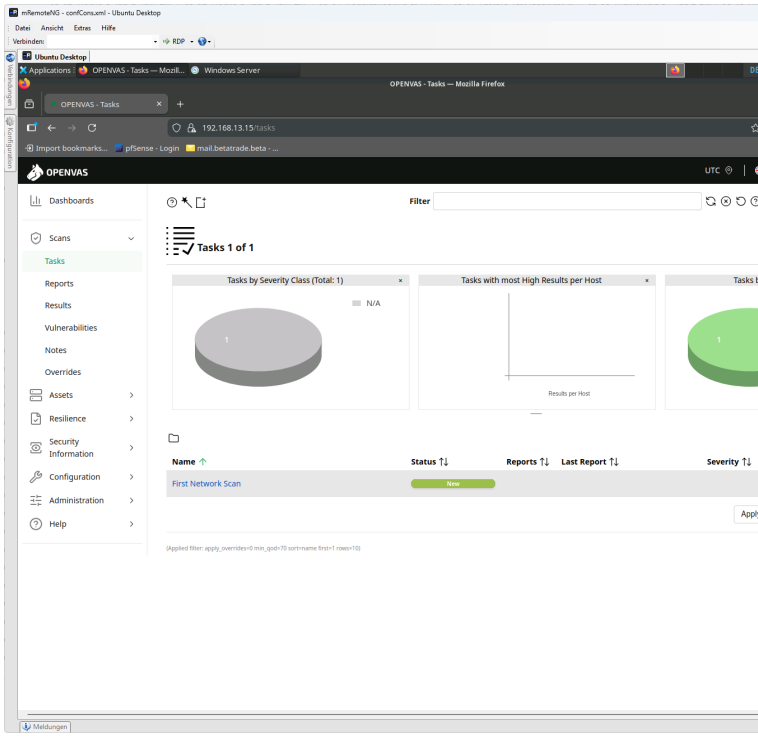
***

Schritt 2: Scan-Task erstellen

Menü: *Scans* → *Tasks* → *New Task*

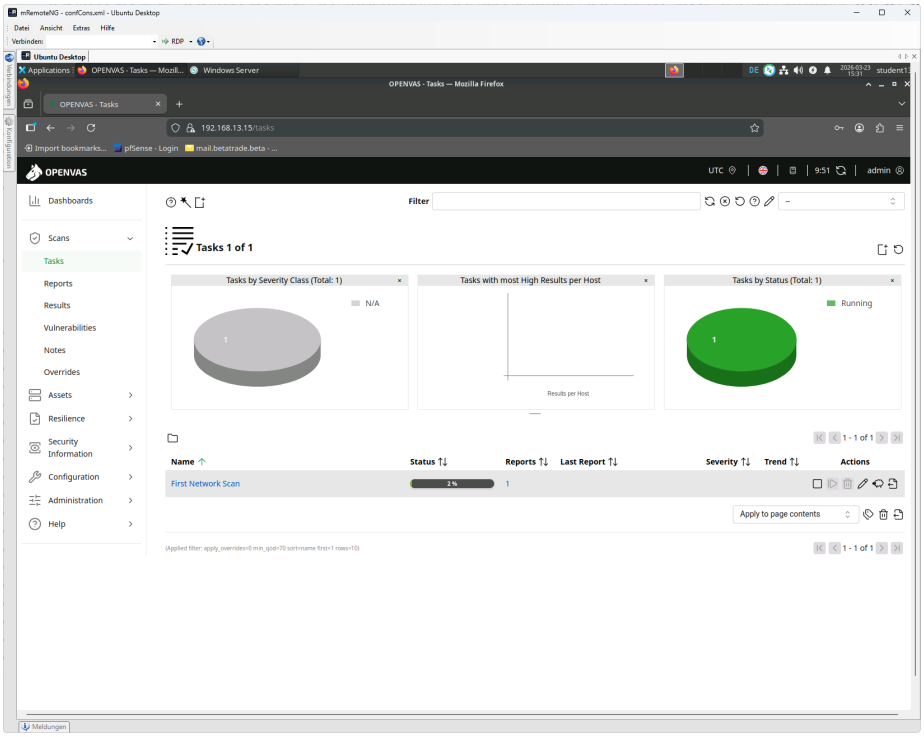
Einstellung	Wert
Task Name	First Scan BetaTrade
Target	BetaTrade-Network
Scan Config	Full and fast
Scanner	OpenVAS Default
Scan-Typ	Non-Credentialed

Scan Config *Full and fast* führt alle NVT-Tests durch und optimiert dabei die



Geschwindigkeit durch parallele Ausführung.
***

Schritt 3: Scan starten



Klick: **Start Scan**
***

3. Scan-Ergebnisse (Übersicht)

Host-Zusammenfassung

Host	Start	Ende	High	Medium	Low	False Positive
10.10.148.71	28. Feb, 00:04:46 UTC	28. Feb, 00:21:02 UTC	1	3	1	0

Port-Übersicht Host 10.10.148.71

Port / Dienst	Bedrohungsstufe
445/tcp (SMB)	HIGH
135/tcp (RPC)	MEDIUM
3389/tcp (RDP)	MEDIUM
general/tcp	LOW

4. Detailanalyse der Schwachstellen

4.1 HIGH – MS17-010 (EternalBlue) – Port 445/tcp

Eigenschaft	Wert
CVSS Score	**9.3 (HIGH)**
Port	445/tcp (SMB)
CVEs	CVE-2017-0143, CVE-2017-0144, CVE-2017-0145, CVE-2017-0146, CVE-2017-0147, CVE-2017-0148
OID	1.3.6.1.4.1.25623.1.0.810676
Microsoft Bulletin	MS17-010 (KB 4013389)
Betroffene OS	Windows Vista SP2, 7 SP1, 8.1, 10, Server 2008/2012/2016

Beschreibung

Der Host ist anfällig für die als **EternalBlue** bekannte SMBv1-Lücke. Mehrere kritische Fehler im Microsoft Server Message Block 1.0 (SMBv1) ermöglichen es Angreifern, speziell präparierte SMB-Anfragen zu senden und damit beliebigen Code auszuführen. Diese Schwachstelle wurde in den NSA-Leaks (Shadow Brokers) veröffentlicht und war der primäre Verbreitungsweg der **WannaCry-Ransomware (Mai 2017)**.

Auswirkungen

- Remote Code Execution (RCE) **ohne Authentifizierung**
- Vollständige Systemübernahme möglich
- Wurm-ähnliche Ausbreitung im Netzwerk
- Datenverlust und Ransomware-Infektion

Lösung

```
# SMBv1 deaktivieren
Set-SmbServerConfiguration -EnableSMB1Protocol $false

# TCP Timestamps deaktivieren (Windows)
netsh int tcp set global timestamps=disabled
```

- Windows Update ausführen → **KB4013389** installieren
- Port 445/tcp in der Firewall blockieren (extern **und** intern)
- Netzwerksegmentierung implementieren

4.2 MEDIUM – DCE/RPC Dienste Enumeration – Port 135/tcp

Eigenschaft	Wert
CVSS Score	**5.0 (MEDIUM)**
Port	135/tcp (DCE/RPC Endpointmapper)
OID	1.3.6.1.4.1.25623.1.0.10736

Erkannte RPC-Endpunkte

Port	UUID	Dienst / Annotation
49152/tcp	d95afe70-a6d5-4259-822e-2c84da1ddb0d	–
49153/tcp	06bba54a-be05-49f9-b0a0-30f790261023	Security Center
49153/tcp	3c4728c5-f0ab-448b-bda1-6ce01eb0a6d5	DHCP Client LRPC Endpoint
49153/tcp	f6beaff7-1e19-4fbb-9f8f-b89e2018337c	Event log TCPIP
49154/tcp	552d076a-cb29-4e44-8b6a-d15e59e2c0af	IP Transition Configuration
49154/tcp	a398e520-d59a-4bdd-aa7a-3c1e0303a511	IKE/Authip API
49158/tcp	367abb81-9844-35f1-ad32-98f038001003	–
49160/tcp	**12345778-1234-abcd-ef00-0123456789ac**	**SAM access (lsass.exe)**

> [!warning] Kritischer Endpunkt Port 49160 exponiert **lsass.exe / SAM-Zugriff** – dies ist besonders sensibel, da lsass.exe Credentials im Speicher hält.

Risiko

Vollständige Auflistung aktiver RPC-Dienste gibt Angreifern detaillierte Infos über Systemarchitektur und angreifbare Schnittstellen.

Lösung

- Port 135/tcp in der Firewall (extern) blockieren
- Windows-Firewall-Regeln für RPC-Endpunkte einschränken
- Unnötige RPC-Dienste deaktivieren

4.3 MEDIUM – Schwache TLS Cipher Suites – Port 3389/tcp (RDP)

Eigenschaft	Wert
CVSS Score	**4.3 (MEDIUM)**
Port	3389/tcp (Remote Desktop Protocol)
OID	1.3.6.1.4.1.25623.1.0.103440
CVEs	CVE-2013-2566 (RC4), CVE-2015-2808 (RC4), CVE-2015-4000 (64-bit)
Protokoll	TLSv1.0
Schwache Suiten	`TLS_RSA_WITH_RC4_128_MD5`, `TLS_RSA_WITH_RC4_128_SHA`

Beschreibung

Der RDP-Dienst akzeptiert über **TLSv1.0** veraltete RC4-basierte Cipher Suites. RC4 gilt seit 2013 als kryptografisch schwach und ist anfällig für statistische Angriffe. TLSv1.0 ist ebenfalls veraltet.

Lösung

- TLSv1.0 und TLSv1.1 vollständig deaktivieren
- RC4-Cipher Suites über Registry deaktivieren
- Nur **TLSv1.2** oder **TLSv1.3** mit starken Suiten erlauben
- Gruppenrichtlinien (GPO) zur TLS-Konfiguration nutzen

4.4 MEDIUM – Schwacher Signatur-Algorithmus (SHA-1) – Port 3389/tcp

Eigenschaft	Wert
CVSS Score	**4.0 (MEDIUM)**
Port	3389/tcp (RDP)
OID	1.3.6.1.4.1.25623.1.0.105880
Zertifikat CN	**Jon-PC**
Signaturalgorithmus	`sha1WithRSAEncryption`

Beschreibung

Das SSL/TLS-Zertifikat des RDP-Dienstes wurde mit **SHA-1** signiert. SHA-1 ist seit Januar 2017 offiziell als unsicher eingestuft. Moderne Angreifer können SHA-1-Kollisionen nutzen, um gefälschte Zertifikate zu erstellen.

Als unsicher geltende Algorithmen

- SHA-1 (Secure Hash Algorithm 1)
- MD5 (Message Digest 5)
- MD4 / MD2

Lösung

- Neues Zertifikat mit **SHA-256 (SHA-2)** ausstellen
- RDP-Zertifikat über Gruppenrichtlinien erneuern
- Zertifikatsmanagement-Prozess etablieren

4.5 LOW – TCP Timestamps aktiv – general/tcp

Eigenschaft	Wert
CVSS Score	**2.6 (LOW)**
Port	general/tcp
OID	1.3.6.1.4.1.25623.1.0.80091
RFC	RFC 1323
Erkannte Timestamps	Paket 1: `41539` | Paket 2: `41668` (Δ = 129 in 1 Sekunde)

Beschreibung

Der Host implementiert TCP Timestamps gemäß RFC 1323. Aus den Zeitstempeln lässt sich näherungsweise die **System-Uptime** berechnen. Kein direkter Angriff, aber wertvolle Reconnaissance-Information.

Lösung

```
# Linux
echo "net.ipv4.tcp_timestamps = 0" >> /etc/sysctl.conf
sysctl -p

# Windows
netsh int tcp set global timestamps=disabled
```

> [!info] Hinweis Windows Ab Windows Server 2008 / Vista kann der Timestamp-Support nicht vollständig deaktiviert werden.

---

5. Risiko-Bewertung

Schwachstelle	Port	CVSS	Stufe	Risiko	Dringlichkeit
MS17-010 (EternalBlue / SMBv1)	445/tcp	9.3	HIGH	RCE, Systemübernahme	Sofort
DCE/RPC Dienst-Enumeration	135/tcp	5.0	MEDIUM	Informationsgewinn	Hoch
Schwache TLS Cipher Suites (RC4)	3389/tcp	4.3	MEDIUM	Man-in-the-Middle	Hoch
SHA-1 Zertifikat (RDP)	3389/tcp	4.0	MEDIUM	Gefälschte Zertifikate	Mittel
TCP Timestamps aktiv	general	2.6	LOW	Uptime erkennbar	Niedrig

---

6. Priorisierung der Maßnahmen

Sofort beheben

- **MS17-010**: KB4013389 installieren, SMBv1 deaktivieren, Port 445 firewallen

Hoch priorisieren (innerhalb 1–2 Wochen)

- RC4-Cipher Suites auf Port 3389 deaktivieren
- TLSv1.0 deaktivieren → auf TLS 1.2+ upgraden
- SHA-1-Zertifikat durch SHA-256-Zertifikat ersetzen
- RPC/Port 135 Zugriff einschränken

Mittelfristig planen

- TCP Timestamps deaktivieren
- Netzwerksegmentierung überprüfen
- **Credentialed Scan** durchführen für tiefere Analyse

---

7. Fazit

Der Scan des Hosts **10.10.148.71** zeigt eine kritische Sicherheitslücke (MS17-010/EternalBlue, CVSS 9.3) auf Port 445/tcp, die unmittelbaren Handlungsbedarf erfordert. Diese Schwachstelle ermöglicht ohne Authentifizierung Remote Code Execution und war der primäre Angriffsvektor für WannaCry.

Drei mittelschwere Schwachstellen (CVSS 4.0–5.0) auf dem RDP-Port 3389 und dem RPC-Port 135 erhöhen die Angriffsfläche zusätzlich.

Kennzahl	Ergebnis
Gefilterte Findings	5 (von 23 Gesamtresultaten)
High	1 (CVSS 9.3 – MS17-010)
Medium	3 (CVSS 4.0–5.0)
Low	1 (CVSS 2.6)
Kritischste Lücke	MS17-010 / EternalBlue → Sofort patchen!
Scan-Typ	Non-Credentialed (Außenangriffsperspektive)
Empfehlung	Credentialed Scan nach Behebung der kritischen Lücken